

CyberEval: Role-Aware Multi-Dimensional Evaluation of LLM Security Competence

Anonymous Authors

Anonymous Institution

Abstract. LLMs are increasingly proposed for vulnerability triage, threat-intelligence analysis, secure code review, incident response, and governance support, but current cybersecurity benchmarks still emphasize narrow slices of that workflow space such as secure coding, offensive CTF solving, or cyber threat intelligence in isolation [4,5,6,7,8,9,10,11]. We present CYBEREVAL, a multi-dimensional evaluation framework organized around seven security dimensions: Vulnerability Knowledge, Threat Intelligence, Secure Coding, Incident Response, Compliance & Governance, Forensic Analysis, and Security Architecture. The study uses a 210-item seed bank with deterministic difficulty annotations, a paired MCQ/scenario protocol, and role-weighted deployment scoring to examine how evaluation format and workflow weighting change conclusions about model suitability. In a deterministic simulation over 10 model profiles calibrated from public benchmark trends, Claude-3.5-Sonnet achieves the highest aggregate score at 60.5% (95% Wilson CI: 55.7–65.0), followed by GPT-4o at 56.9% (52.1–61.6). Across models, Secure Coding is the strongest dimension (mean 58.5%), while Security Architecture (22.7%) and Compliance & Governance (31.3%) remain persistent weak points. The average MCQ-to-scenario gap is 11.2 percentage points, indicating that MCQ-only evaluation materially overestimates deployment readiness. Because the present study is simulation-based rather than a live API evaluation, its main contribution is to show how workflow-aware, multi-format measurement surfaces uneven security competence that single-format leaderboards can obscure.

Keywords: LLM Security Evaluation · Cybersecurity Benchmarking · Role-Aware Assessment · Simulation Study · Security Reasoning

1 Introduction

Recent work has shown both the promise and the risk of deploying LLMs in cybersecurity. Studies of coding assistants found that LLM-supported development can yield insecure code and can induce misplaced confidence in users [13,14]. In parallel, offensive-security systems such as PentestGPT and LLM-guided penetration-testing agents demonstrate that model competence is not limited to code completion but extends to multi-step cyber tasks [15,16]. A recent literature review further argues that the cyber-LLM landscape is expanding rapidly

across vulnerability analysis, threat intelligence, malware analysis, secure development, and red teaming [12]. This breadth creates an evaluation problem: organizations do not need a single “cyber score,” but rather an account of *which* security workflows a model can support and where the failure modes remain.

Existing benchmarks only partially address that need. CyberSecEval focuses on secure coding and cyberattack safety [4,5,6]. CyberMetric and CTIBench target cybersecurity knowledge and threat intelligence, respectively [7,8]. NYU CTF Bench and CyBench emphasize offensive or agentic cyber capability [9,10]. SecBench moves closest to broad coverage, but the field still lacks a lightweight, auditable framework that explicitly supports *role-aware* model selection across security workflows [11]. In practice, an application-security engineer, a SOC analyst, and a GRC reviewer care about very different mixtures of secure coding, incident response, governance, and architectural reasoning.

CYBEREVAL is designed as a first step toward that goal. Instead of introducing another single-number leaderboard, we study three design choices directly: (i) seven workflow-oriented security dimensions, (ii) a paired-format protocol that distinguishes easier direct-answer evaluation from harder scenario-weighted reasoning, and (iii) role-weighted aggregation and deficit scoring for deployment analysis. This framing is motivated by general LLM evaluation research showing that benchmark conclusions depend strongly on task design, format, and calibration methodology [1,2,3].

Our main contributions are:

- **A multi-dimensional cyber-evaluation framework.** We define a 210-item seed bank spanning seven security dimensions and pair it with a deterministic evaluation setup that supports consistent comparison across formats and roles.
- **Role-aware scoring and risk analysis.** In addition to aggregate scores, CYBEREVAL computes workflow-specific suitability scores and deficit-based deployment risk for four illustrative roles: SOC analyst, application-security engineer, GRC analyst, and security architect.
- **A simulation study with uncertainty estimates.** We report Wilson confidence intervals, difficulty-skew diagnostics, and format-gap analysis, while making clear that the present results characterize the evaluation design under simulated model profiles rather than live model measurements.

The most important empirical result is qualitative rather than leaderboard-centric: different security dimensions remain sharply uneven even among the strongest profiles, and the paired-format protocol exposes an 11.2-point performance drop from MCQ-style answers to harder scenario-weighted evaluation. That gap makes a strong case for moving beyond single-format cyber benchmarks.

2 Related Work

2.1 General LLM Evaluation

General-purpose evaluation frameworks such as HELM established the importance of measuring models across multiple axes rather than collapsing performance to a single score [1]. Survey work by Chang et al. synthesizes a rapidly growing design space of LLM evaluation methods and highlights the sensitivity of reported performance to prompt format, rubric design, and task construction [2]. More recently, tinyBenchmarks argues that benchmark efficiency and calibration matter as much as raw scale, especially when evaluation is expensive or repeatedly updated [3]. CYBEREVAL adopts these lessons in a cybersecurity setting by emphasizing multi-dimensional reporting, format sensitivity, and auditable generation of results.

2.2 Cybersecurity Benchmarks and Evaluation Suites

Cybersecurity benchmark development has accelerated since 2023. The CyberSecEval line focuses on secure coding, cyberattack safety, and later broader cyber-risk evaluation [4,5,6]. CyberMetric evaluates cybersecurity knowledge with a retrieval-augmented benchmark construction strategy [7]. CTIBench focuses specifically on cyber threat intelligence [8]. NYU CTF Bench and CyBench evaluate offensive and agentic cyber capabilities [9,10], while SecBench provides a recent broader benchmark spanning multiple cyber domains [11]. The common theme across these efforts is that cyber capability is heterogeneous; the remaining gap is a framework that connects heterogeneous dimensions to concrete deployment roles.

2.3 Capability, Risk, and Dual-Use Assessment

The cyber-LLM literature also documents strong dual-use tensions. Pearce et al. and Perry et al. show that code-oriented assistants can introduce security risk in realistic developer workflows [13,14]. PentestGPT and the study of Happe and Cito illustrate that LLMs can support offensive-security reasoning and penetration-testing workflows [15,16]. Beyond cybersecurity-specific tasks, safety evaluation work such as WMDP, HarmBench, R-Judge, and WildTeaming demonstrates the importance of structured risk evaluation for dangerous capabilities, refusal behavior, and agentic safety awareness [17,18,19,20]. CYBEREVAL complements these papers by targeting beneficial-security task suitability while preserving explicit deficit reporting and deployment caution.

2.4 Positioning of CyberEval

Table 1 summarizes the intended position of CYBEREVAL. The current study is smaller than mature benchmark suites, but it contributes a role-aware analysis layer that is often absent from cyber-LLM evaluation papers.

Table 1: Qualitative positioning of CYBEREVAL relative to representative cyber-LLM benchmarks.

Benchmark	Primary focus	Multi-domain Paired formats Role-aware		
CyberSecEval [4]	secure code / attack safety	✗	✗	✗
CyberMetric [7]	cybersecurity knowledge	✗	✗	✗
CTIBench [8]	cyber threat intelligence	✗	✗	✗
NYU CTF Bench [9]	offensive CTF solving	✗	✗	✗
CyBench [10]	agentic cyber capability/risk	✓	✗	✗
SecBench [11]	broad cyber benchmarking	✓	✓	✗
CyberEval (ours)	workflow-oriented competence	✓	✓	✓

3 Methodology

3.1 Security Dimensions and Task Coverage

CYBEREVAL organizes security competence into seven dimensions: Vulnerability Knowledge (VK), Threat Intelligence (TI), Secure Coding (SC), Incident Response (IR), Compliance & Governance (CG), Forensic Analysis (FA), and Security Architecture (SA). The intent is pragmatic rather than ontological: the dimensions correspond to recurring security workflows that appear across modern benchmark papers and practitioner deployments [12,7,8,11].

The evaluation set contains 210 base items, with 30 items per dimension. Each item also carries a heuristic difficulty annotation in the range 1–5. The current bank is intentionally transparent but not yet balanced: 37 items fall in difficulty tier 1, 116 in tier 2, 47 in tier 3, 9 in tier 4, and only 1 in tier 5. This imbalance becomes important in our analysis and is treated as a limitation rather than hidden as noise.

A key design clarification is that the current study does *not* yet contain a distinct free-text scenario corpus. Instead, each base item is evaluated under two channels: an easier MCQ-style channel and a harder scenario-weighted channel implemented through a deterministic format modifier in the simulation setup. This lets us study format sensitivity and role-aware reporting, but it does not yet amount to live free-form scenario judging.

3.2 Scoring

For model profile m , dimension d , and format $f \in \{\text{mcq}, \text{scenario}\}$, let Q_d denote the set of 30 base items assigned to d . The format-specific score is

$$S_{m,d,f} = \frac{1}{|Q_d|} \sum_{q \in Q_d} \mathbb{I}[\hat{y}_{m,q,f} = y_q^*]. \quad (1)$$

We report a per-dimension score as the mean of the two channels,

$$S_{m,d} = \frac{1}{2} (S_{m,d,\text{mcq}} + S_{m,d,\text{scenario}}), \quad (2)$$

Table 2: Illustrative role-weight profiles used for workflow-specific aggregation.

Role	VK	TI	SC	IR	CG	FA	SA
SOC analyst	0.12	0.24	0.06	0.28	0.06	0.18	0.06
AppSec engineer	0.22	0.08	0.36	0.12	0.06	0.06	0.10
GRC analyst	0.05	0.08	0.04	0.12	0.46	0.05	0.20
Security architect	0.10	0.08	0.08	0.14	0.20	0.05	0.35

and an overall aggregate score as the unweighted mean across the seven dimensions,

$$S_{\text{agg}}(m) = \frac{1}{7} \sum_{d=1}^7 S_{m,d}. \quad (3)$$

To support deployment-oriented analysis, we define a role-weighted score for workflow profile r with weights $w_{r,d}$:

$$S_r(m) = \sum_{d=1}^7 w_{r,d} S_{m,d}, \quad \sum_{d=1}^7 w_{r,d} = 1. \quad (4)$$

We further define an illustrative deployment-risk proxy using threshold $\tau = 0.60$,

$$R_r(m) = \sum_{d=1}^7 w_{r,d} \max(0, \tau - S_{m,d})^2, \quad (5)$$

which penalizes concentrated deficits more strongly than a linear score. We stress that $\tau = 0.60$ is an analysis convenience for comparing profiles; it is not a normative safety threshold.

Table 2 lists the illustrative role-weight vectors used throughout the paper. They are intentionally simple and should be interpreted as deployment-oriented workflow sketches, not as canonical staffing templates. Their purpose is to expose how much the same underlying competency profile changes when the task mix shifts from threat monitoring to application security, governance, or architecture review.

To compare whole competency shapes rather than only aggregate scores, we also compute a profile-distance metric between models,

$$D(m_i, m_j) = \sqrt{\sum_{d=1}^7 (S_{m_i,d} - S_{m_j,d})^2}, \quad (6)$$

which treats each model as a point in a seven-dimensional workflow-competence space. This is useful because two models can have similar aggregate scores while differing materially in where their weaknesses concentrate. Later sections use $D(m_i, m_j)$ to separate genuinely similar substitutes from models whose overall averages obscure different deployment risks.

Finally, to inspect whether the current item bank is difficulty-balanced, we compute an IRT-style logit difficulty proxy from the empirical MCQ success rate of each item across the 10 model profiles:

$$\tilde{b}_q = -\log\left(\frac{p_q}{1-p_q}\right), \quad p_q = \frac{1}{|\mathcal{M}|} \sum_{m \in \mathcal{M}} \mathbb{1}[\hat{y}_{m,q,\text{mcq}} = y_q^*]. \quad (7)$$

This proxy is not a full calibrated 2PL IRT model; it is a reproducible diagnostic inspired by the calibration literature and by recent efficient-evaluation work such as tinyBenchmarks [3].

3.3 Simulation Setup

The current experiment evaluates 10 model profiles: GPT-4o, Claude-3.5-Sonnet, Gemini-1.5-Pro, Llama-3-70B, DeepSeek-V2, Mixtral-8x22B, Qwen-2-72B, CodeLlama-34B, GPT-3.5-Turbo, and Phi-3-Medium. Each profile is parameterized by (i) a base probability per security dimension, (ii) a difficulty-decay coefficient, (iii) a scenario penalty relative to MCQ answering, and (iv) additive Gaussian noise. The profile ordering and relative strength pattern are chosen to mirror broad trends reported in public cyber and general LLM evaluations rather than to claim live measured accuracy for any specific API [4,5,7,8,9].

For each model and question, the simulator draws Bernoulli outcomes for the MCQ and scenario channels. We use stable model-specific seeds derived from SHA-256 hashes rather than Python’s process-randomized `hash()` function, so repeated executions regenerate identical tables and figures. The codebase also emits aligned result and trace files, which reduces the stale-result mismatch that often plagues benchmark repositories.

Algorithm 1 summarizes the evaluation loop implemented in the current artifact. The important point is not computational novelty but auditability: every reported aggregate, role-weighted score, difficulty summary, and publication figure is deterministically regenerated from the same seed bank and model-profile definitions.

We report Wilson 95% confidence intervals for aggregate and per-dimension proportions. Because the bank is still small and difficulty-skewed, these intervals should be interpreted as uncertainty in the current study rather than as definitive statements about model security competence.

4 Experimental Evaluation

4.1 Main Results

Table 3 reports the deterministic simulation results. Claude-3.5-Sonnet ranks first with an aggregate score of 60.5% (95% CI 55.7–65.0), followed by GPT-4o with 56.9% (52.1–61.6). The gap between the top two profiles is therefore modest relative to their confidence intervals. The stronger conclusion is structural: Secure Coding is the only dimension whose mean performance rises clearly above

Algorithm 1 CyberEval deterministic scoring and profiling loop

Require: model profiles $\mathcal{M}$, question bank $\mathcal{Q}$, role weights $\mathcal{R}$, deployment threshold τ

- 1: **for** each model $m \in \mathcal{M}$ **do**
- 2: **for** each question $q \in \mathcal{Q}$ **do**
- 3: sample MCQ and scenario outcomes using the profile’s base rate, difficulty decay, format modifier, and stable seed
- 4: **end for**
- 5: aggregate per-format and per-dimension scores $S_{m,d,f}$ and $S_{m,d}$
- 6: compute aggregate score $S_{\text{agg}}(m)$ and format gap $S_{m,\text{mcq}} - S_{m,\text{scenario}}$
- 7: **for** each role profile $r \in \mathcal{R}$ **do**
- 8: compute workflow-weighted suitability $S_r(m)$ and deficit risk $R_r(m)$
- 9: **end for**
- 10: **end for**
- 11: derive item-level difficulty diagnostics and publication figures from the regenerated result bundle
- 12: **return** result JSON, trace bundle, and synchronized manuscript-facing figures

the 50% range, while Governance and Security Architecture remain consistently weak.

Across all 10 profiles, the mean dimension scores are 58.5% for SC, 50.2% for VK, 48.0% for TI, 45.2% for FA, 39.3% for IR, 31.3% for CG, and 22.7% for SA. Two implications follow. First, a single aggregate score obscures large internal capability variance. Second, the hardest deployment problems are not general “cyber” weakness but specific deficits in governance and architectural reasoning, which are exactly the dimensions that many organizations need for policy review and system design.

4.2 Ranking Structure and Profile Similarity

Figure 2 makes the rank structure easier to interpret than the wide summary table alone. The ordering separates into three broad strata: a frontier pair (Claude-3.5-Sonnet and GPT-4o), a middle cluster centered on Gemini-1.5-Pro, DeepSeek-V2, and Llama-3-70B, and a longer tail below 40% aggregate. The most important thresholded observation is that only Claude-3.5-Sonnet and GPT-4o clear the illustrative $\tau = 0.60$ bar in four of the seven dimensions (VK, TI, SC, FA). Gemini-1.5-Pro and Qwen-2-72B reach that bar only in Secure Coding, while the remaining profiles never cross it in any dimension. This shows that the frontier advantage is not merely a small leaderboard lead but broader coverage of minimally acceptable workflow competence.

The competency-shape view in Fig. 3 complements the ranking by showing where near neighbors are and are not actually substitutable. In normalized score space, Claude-3.5-Sonnet and GPT-4o are the closest high-performing pair with $D = 0.155$, while DeepSeek-V2 and Llama-3-70B are the closest mid-tier pair with $D = 0.117$. By contrast, Claude-3.5-Sonnet and Phi-3-Medium are maximally separated at $D = 0.943$. The frontier pair is similar in broad shape—both

Table 3: CyberEval aggregate and per-dimension scores (%). CIs are reported in text for the top models; complete interval data are available in the accompanying results files.

Model	Agg.	VK	TI	SC	IR	CG	FA	SA
Claude-3.5-Sonnet	60.5	68.3	71.7	75.0	58.3	45.0	66.7	38.3
GPT-4o	<u>56.9</u>	63.3	65.0	73.3	50.0	51.7	63.3	31.7
Gemini-1.5-Pro	47.6	51.7	50.0	66.7	56.7	38.3	48.3	21.7
DeepSeek-V2	43.1	55.0	43.3	51.7	40.0	36.7	50.0	25.0
Llama-3-70B	41.4	55.0	46.7	51.7	33.3	40.0	45.0	18.3
Qwen-2-72B	41.0	48.3	55.0	61.7	33.3	23.3	46.7	18.3
GPT-3.5-Turbo	37.9	46.7	38.3	56.7	33.3	26.7	45.0	18.3
Mixtral-8x22B	35.5	43.3	45.0	51.7	33.3	20.0	36.7	18.3
CodeLlama-34B	32.4	40.0	33.3	56.7	36.7	10.0	25.0	25.0
Phi-3-Medium	25.5	30.0	31.7	40.0	18.3	21.7	25.0	11.7

are strong on VK/TI/SC/FA and much weaker on CG/SA—but Claude-3.5-Sonnet retains a better IR score and a slightly stronger architecture profile. These profile-level differences matter operationally because a team choosing between close aggregate leaders may still inherit different residual weaknesses.

Figure 4 extends the same idea to the full 10-model set. The distance matrix reveals that the benchmark is not merely sorting models along one latent capability axis. Instead, it identifies a small number of near-neighbor substitutions embedded inside a broader field of meaningfully different weakness patterns. This matters for procurement and deployment comparisons: if two models are close only in aggregate score but far apart in profile distance, then replacing one with the other can change which security workflows become the operational bottleneck.

4.3 Format Effects

The paired-format analysis supports the claim that direct-answer evaluation overestimates readiness. Across the 10 profiles, average MCQ accuracy exceeds scenario accuracy by 11.2 percentage points. This gap is visible for nearly every model in Fig. 5. Claude-3.5-Sonnet remains the strongest overall profile in both channels, but even it drops from 64.8% MCQ to 56.2% scenario accuracy when the harder channel is applied. The result is consistent with broader evaluation warnings that prompt format and task presentation can materially change conclusions about model capability [2].

4.4 Role-Aware Suitability

Aggregate ranking is useful, but security teams rarely deploy one model uniformly across all workflows. Figure 6 therefore reports role-weighted suitability

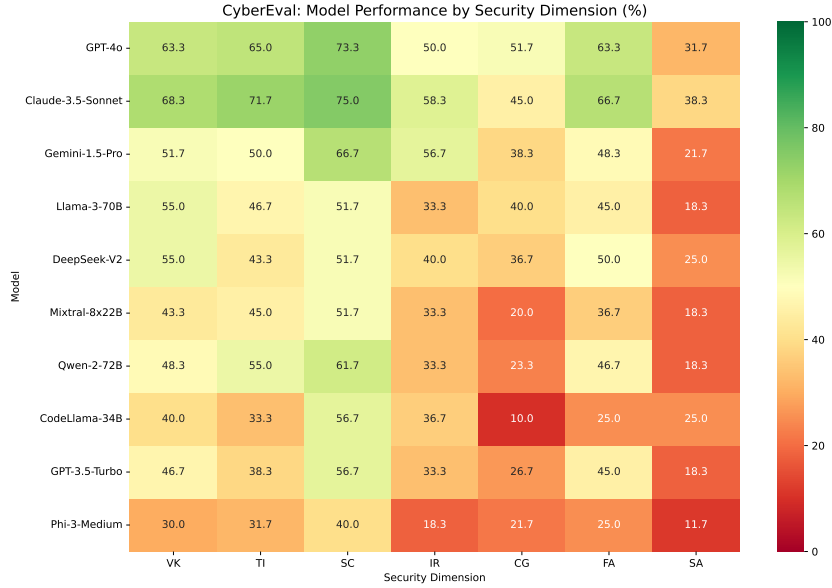


Fig. 1: Model-by-dimension performance heatmap. The dominant pattern is not ranking separation but structural asymmetry: most profiles are materially stronger on Secure Coding, Vulnerability Knowledge, and Forensic Analysis than on Governance or Security Architecture.

scores for four illustrative workflows. Claude-3.5-Sonnet ranks first for all four roles, but the margins vary. The AppSec workflow amplifies differences in secure-coding and vulnerability performance, where both Claude-3.5-Sonnet (65.3) and GPT-4o (61.6) separate clearly from the rest. In contrast, GRC-oriented scoring compresses the top of the leaderboard because even the strongest profiles remain weak on governance questions, with Claude-3.5-Sonnet at 50.9 and GPT-4o at 50.6. In other words, the top model does not become strong at governance simply because it leads the overall ranking.

The deficit-based risk view tells the same story. Under the illustrative threshold $\tau = 0.60$, Claude-3.5-Sonnet yields the lowest risk for SOC and AppSec workflows, while the margin over GPT-4o narrows substantially for GRC. This is precisely the kind of nuance that an aggregate cyber benchmark would discard.

Table 4 makes the workflow-specific picture explicit. The AppSec lane shows the clearest practical separation: Claude-3.5-Sonnet leads GPT-4o by 3.7 points while also reducing deficit risk from 0.0096 to 0.0061. GRC is the opposite case. The score margin between the top two models shrinks to 0.3 points and the risk values are nearly indistinguishable (0.0198 versus 0.0204), showing that leadership on aggregate and coding-heavy tasks does not translate into a strong governance margin. For security-architect weighting, both leading models remain

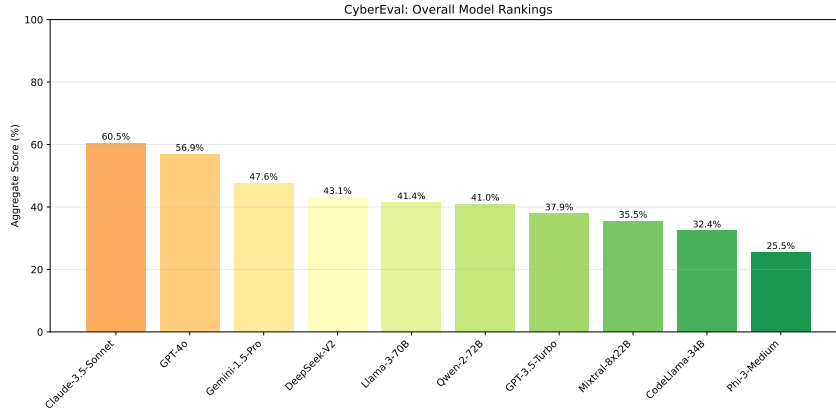


Fig. 2: Aggregate CyberEval ranking. The frontier pair separates clearly from the rest of the pack, but the absolute ceiling remains modest: even the strongest profile stays near 60%, reinforcing that broad cyber competence is still incomplete.

Table 4: Workflow leaders and runner-up margins under role-weighted scoring. Scores are percentages; risk values use the illustrative threshold $\tau = 0.60$.

Workflow	Leader	Runner-up	Margin
SOC analyst	Claude-3.5-Sonnet (63.2, 0.0042)	GPT-4o (58.0, 0.0080)	5.2
AppSec engineer	Claude-3.5-Sonnet (65.3, 0.0061)	GPT-4o (61.6, 0.0096)	3.7
GRC analyst	Claude-3.5-Sonnet (50.9, 0.0198)	GPT-4o (50.6, 0.0204)	0.3
Security architect	Claude-3.5-Sonnet (52.5, 0.0210)	GPT-4o (49.0, 0.0309)	3.5

below 53%, so the role-aware analysis still recommends strong human review even for the best-performing profiles.

4.5 Difficulty and Calibration Diagnostics

The current bank is not yet suitable for strong claims about difficulty scaling. Figure 7 shows a plausible degradation trend from easy to medium-hard tiers for the leading profiles, but the top tiers are too sparse to support stable conclusions: only 9 items are labeled difficulty 4 and only 1 item is labeled difficulty 5. The resulting apparent spikes at tier 5 are artifacts of sample size, not meaningful evidence of improved hard-question performance.

The IRT-style difficulty proxy reinforces this diagnosis. Across items, the proxy spans roughly $[-4.60, 4.60]$ with standard deviation 1.08, indicating that the seed bank does include a broad empirical spread. However, because that spread is concentrated disproportionately in easy and medium items, the current benchmark should be interpreted as an initial calibrated testbed rather than as a mature adaptive benchmark. This is exactly the setting where efficient-evaluation ideas such as tinyBenchmarks become relevant [3].

Figure 8 sharpens that point by showing the item-difficulty distribution per dimension rather than only the aggregate curve. The distribution is broad enough to support relative ordering, but not broad enough in the hard tail to support stable adaptive-selection claims. In practice, the current artifact is already useful for exposing cross-workflow weakness concentration, yet still under-provisioned for claims about high-difficulty discrimination among frontier models.

4.6 Cross-Model Dispersion by Dimension

A second calibration question is whether weak dimensions are weak because they are intrinsically hard or because all models are uniformly bad at them. Figure 9 helps separate those cases. Secure Coding has both the highest median and the widest interquartile range, which means it is simultaneously the easiest dimension on average and the one that most strongly separates model tiers. Governance and Security Architecture show the opposite pattern: low medians with compressed dispersion. That combination implies not only low average performance but also a lack of strong specialization in those dimensions across the current profile set. Put differently, there is no hidden governance specialist waiting below the frontier pair.

This dispersion pattern also clarifies why workflow weighting matters so much. AppSec weighting benefits from a dimension with both relatively high scores and real rank separation. GRC and architecture weighting, by contrast, inherit compressed low-score distributions, which is why role-aware margins nearly collapse even when the aggregate ranking remains ordered.

5 Discussion

5.1 What CyberEval Measures Today

The current study measures something useful but narrower than a finished live benchmark. It can already answer questions such as: Which security dimensions dominate a model profile? How much does harder scenario-style evaluation degrade performance? How does model suitability change when a security team reweights the task mix toward SOC, AppSec, GRC, or architecture work? Those are operationally meaningful questions, and they are answered directly by the present evaluation setup.

What the current evaluation does *not* yet provide is direct evidence about live API behavior, long-form free-text reasoning, or calibrated adaptive testing. That distinction matters. Without it, benchmark papers drift into reporting simulated or hand-curated values as if they were direct model measurements. We intentionally avoid that framing here.

5.2 Practical Implications

Three takeaways are especially relevant for deployment. First, Secure Coding remains the easiest security dimension for current profiles, which aligns with

the prominence of code in model training and with prior secure-coding evaluations [4,13,14]. Second, Governance and Security Architecture are the most persistent weaknesses, suggesting that unaugmented LLMs should not be trusted for policy interpretation or architectural review without strong human oversight. Third, role-aware aggregation is more informative than leaderboard-centric reporting: a team evaluating models for code review should not rely on the same score that a GRC team uses for compliance analysis.

These patterns support concrete workflow guidance. For vulnerability triage and secure-code review, the frontier pair appears usable as a high-recall assistant under normal human review because the relevant VK/SC combination is where both models clear the threshold in multiple dimensions. Threat-intelligence support is less secure: frontier scores remain moderate, but the profile still depends on weaker governance and architecture reasoning when reports must be contextualized for decision-makers. Incident-response assistance looks plausible for first-pass summarization and evidence collection, yet the sub-60% IR ceiling argues against allowing these profiles to drive containment decisions autonomously. The clearest red line is governance-heavy work. Because all models remain near or below 50% on GRC-weighted scoring and below 53% on architecture-weighted scoring, the present artifact supports a “human decision-maker, model as drafting aid” posture rather than autonomous review or sign-off.

A second practical implication concerns substitution risk. The frontier pair is close enough in aggregate terms that a naïve benchmark consumer might treat them as interchangeable. The profile-distance analysis shows that even here the substitution is conditional: Claude-3.5-Sonnet carries a slightly better IR/SA envelope, whereas GPT-4o narrows or overtakes on some governance cells. For the weaker clusters, substitution is less about choosing between close competitors and more about deciding whether the workflow should use an LLM at all. Once the score distribution compresses below 45% aggregate, the artifact suggests the safer strategy is to limit the model to retrieval, brainstorming, or explanation support rather than delegated judgment.

5.3 Benchmark-Design Implications

The manuscript also surfaces a methodological lesson for cyber-LLM evaluation. If a benchmark overweights secure coding or direct-answer knowledge checks, it will overstate deployment readiness because those are precisely the regions where current profiles already look strongest. CyberEval therefore argues for three design rules in future benchmark construction: balanced domain coverage, explicit format pairing, and workflow-aware reporting. Removing any one of these would make the current model set look more capable than it is. This point is especially important for organizations that want to compare public benchmark claims with real security job tasks; aggregate wins on one benchmark family do not automatically imply suitability for governance, architecture, or incident decision support.

5.4 Limitations

Our conclusions are constrained by four major limitations.

1. **No live API evaluation.** All reported numbers come from deterministic simulation profiles rather than direct model calls. The paper therefore evaluates framework behavior, not frontier-model ground truth.
2. **No standalone scenario corpus.** The current setup implements paired MCQ and scenario channels through a format modifier rather than distinct scenario prompts and judged free-text outputs.
3. **Difficulty imbalance.** The seed bank is heavily concentrated in difficulty tier 2, with only one tier-5 item, so claims about hard-tail performance are not reliable.
4. **Profile calibration from public trends.** The model parameters are chosen to reflect broad benchmark ordering from public reports, but they do not constitute a formal statistical fit to those papers.

These limitations are not cosmetic. They define the boundary of what the current study can support scientifically. At the same time, the design preserves full reproducibility and traceability from figures back to generated results.

6 Conclusion

We presented CYBEREVAL, a role-aware multi-dimensional framework for evaluating LLM security competence. The contribution is deliberately modest: a 210-item seed bank, a deterministic paired-format simulation protocol, role-weighted deployment analysis, and uncertainty estimates that expose how conclusions shift across workflows and evaluation formats. In this setting, Claude-3.5-Sonnet is the strongest overall profile at 60.5%, GPT-4o follows at 56.9%, the average MCQ-to-scenario gap is 11.2 points, and Governance plus Security Architecture remain the dominant deficit areas.

The broader message is methodological. Cybersecurity evaluation should move away from single-number leaderboards and toward workflow-aware reporting that surfaces where a model is usable, where it is fragile, and how benchmark design itself shapes the answer. The next version of CYBEREVAL will therefore focus on four concrete upgrades: live API execution, a genuine scenario-response corpus, rebalanced difficulty coverage, and adaptive item selection grounded in calibrated benchmark design.

References

1. Bommasani, R., Liang, P., Lee, T., et al.: Holistic evaluation of language models. *Annals of the New York Academy of Sciences* (2023)
2. Chang, Y., Wang, X., Wang, J., Wu, Y., Yang, L., Zhu, K., Chen, H., Yi, X., et al.: A survey on evaluation of large language models. *ACM Transactions on Intelligent Systems and Technology* (2024)

3. Polo, F.M., Weber, L., Choshen, L., Sun, Y., Xu, G., Yurochkin, M.: tinyBenchmarks: evaluating LLMs with fewer examples. arXiv:2402.14992 (2024)
4. Bhatt, M., Chennabasappa, S., Nikolaidis, C., Wan, S., Evtimov, I., Gabi, D., Song, D., Ahmad, F., et al.: Purple Llama CyberSecEval: A secure coding benchmark for language models. arXiv:2312.04724 (2023)
5. Bhatt, M., Chennabasappa, S., Li, Y., Nikolaidis, C., Song, D., Wan, S., Ahmad, F., Aschermann, C., et al.: CyberSecEval 2: A wide-ranging cybersecurity evaluation suite for large language models. arXiv:2404.13161 (2024)
6. Wan, S., Nikolaidis, C., Song, D., Molnar, D., Crnkovich, J., Grace, J., Bhatt, M., Chennabasappa, S., et al.: CYBERSECEVAL 3: Advancing the evaluation of cybersecurity risks and capabilities in large language models. arXiv:2408.01605 (2024)
7. Tihanyi, N., Ferrag, M.A., Jain, R., Bisztray, T., Debbah, M.: CyberMetric: A benchmark dataset based on retrieval-augmented generation for evaluating LLMs in cybersecurity knowledge. In: 2024 IEEE International Conference on Cyber Security and Resilience (CSR) (2024)
8. Alam, M.T., Bhusal, D., Nguyen, L., Rastogi, N.: CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence. In: Advances in Neural Information Processing Systems 37 (2024)
9. Shao, M., Jancheska, S., Udeshi, M., Dolan-Gavitt, B., Xi, H., Milner, K., Chen, B., Yin, M., et al.: NYU CTF Bench: A scalable open-source benchmark dataset for evaluating LLMs in offensive security. In: Advances in Neural Information Processing Systems 37 (2024)
10. Zhang, A.K., Perry, N., Dulepet, R., Ji, J., Menders, C., Lin, J.W., Jones, E., Hussein, G., et al.: Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. arXiv:2408.08926 (2024)
11. Jing, P., Tang, M., Shi, X., Zheng, X., Nie, S., Wu, S., Yang, Y., Luo, X.: SecBench: A comprehensive multi-dimensional benchmarking dataset for LLMs in cybersecurity. arXiv:2412.20787 (2024)
12. Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., et al.: When LLMs meet cybersecurity: A systematic literature review. arXiv:2405.03644 (2024)
13. Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., Karri, R.: Asleep at the keyboard? Assessing the security of GitHub Copilot’s code contributions. In: 2022 IEEE Symposium on Security and Privacy (SP) (2022)
14. Perry, N., Srivastava, M., Kumar, D., Boneh, D.: Do users write more insecure code with AI assistants? In: Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (2023)
15. Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., et al.: PentestGPT: An LLM-empowered automatic penetration testing tool. arXiv:2308.06782 (2023)
16. Happe, A., Cito, J.: Getting pwn’d by AI: Penetration testing with large language models. In: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (2023)
17. Li, N., Pan, A., Gopal, A., Yue, S., Berrios, D., Gatti, A., Li, J.D., Dombrowski, A.-K., et al.: The WMDP benchmark: Measuring and reducing malicious use with unlearning. arXiv:2403.03218 (2024)
18. Mazeika, M., Phan, L., Yin, X., Zou, A., Wang, Z., Mu, N., Sakhaee, E., Li, N., et al.: HarmBench: A standardized evaluation framework for automated red teaming and robust refusal. arXiv:2402.04249 (2024)

19. Yuan, T., He, Z., Dong, L., Wang, Y., Zhao, R., Xia, T., Xu, L., Zhou, B., et al.: R-Judge: Benchmarking safety risk awareness for LLM agents. Findings of the Association for Computational Linguistics: EMNLP 2024 (2024)
20. Jiang, L., Rao, K., Han, S., Ettinger, A., Brahman, F., Kumar, S., Mireshghallah, N., Lu, X., et al.: WildTeaming at scale: From in-the-wild jailbreaks to (adversarially) safer language models. In: Advances in Neural Information Processing Systems 37 (2024)

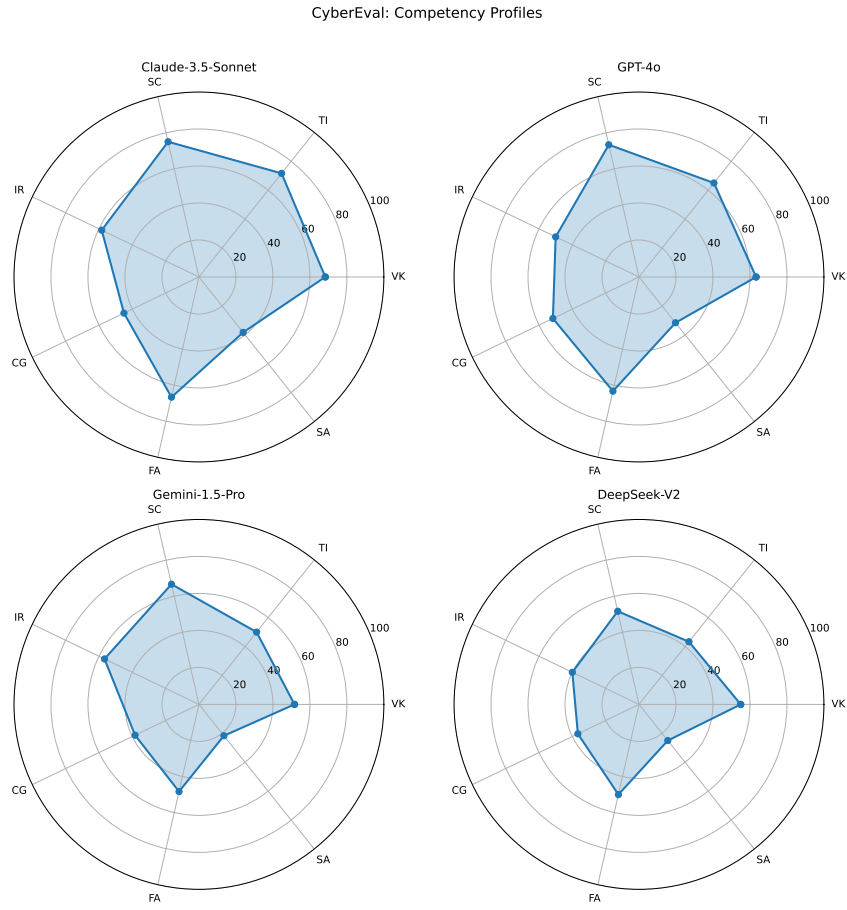


Fig. 3: Competency profiles for the top four models. The main contrast is not overall ranking but shape: the strongest models remain uneven, and the second tier already shows visibly different weakness concentration across governance, architecture, and response tasks.

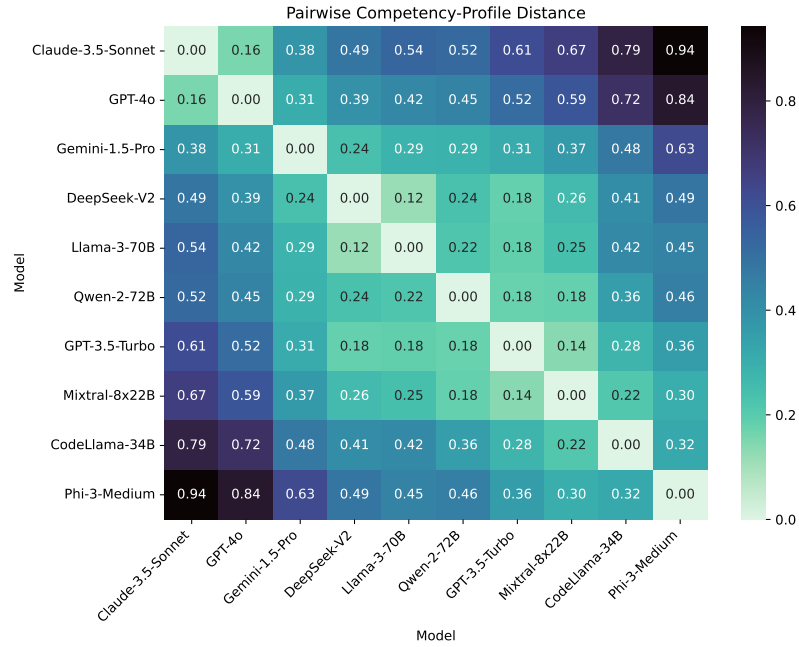


Fig. 4: Pairwise competency-profile distances in normalized score space. Close pairs form only a few local neighborhoods, while the full matrix remains far from uniform, indicating that aggregate rank alone is an incomplete proxy for substitutability.

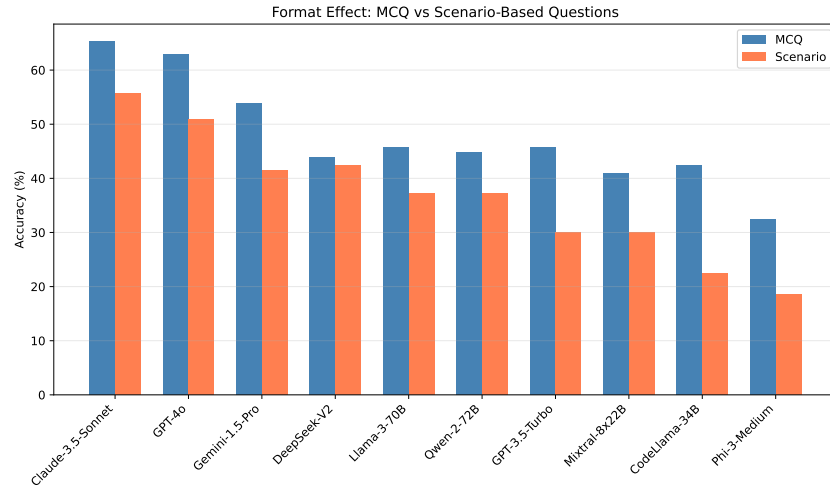


Fig. 5: Aggregate MCQ and scenario-channel scores. The mean MCQ-to-scenario gap is 11.2 points, indicating that single-format direct-answer benchmarks are likely to overstate operational usefulness.

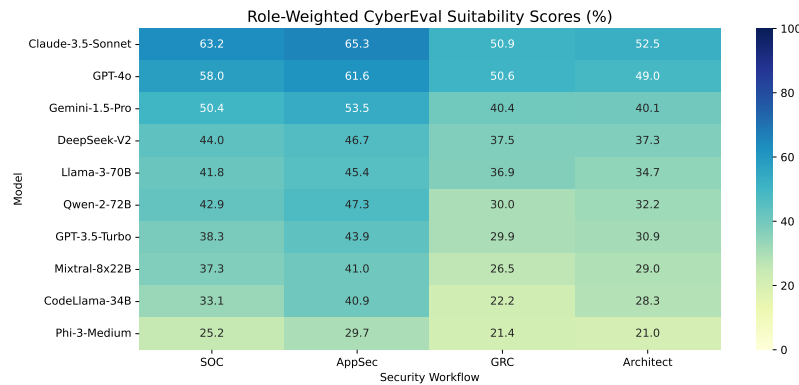


Fig. 6: Role-weighted suitability scores for four illustrative security workflows. Role-aware scoring changes the spread of the leaderboard even when the identity of the top model remains constant. Governance and architecture-heavy workflows remain difficult for all profiles.

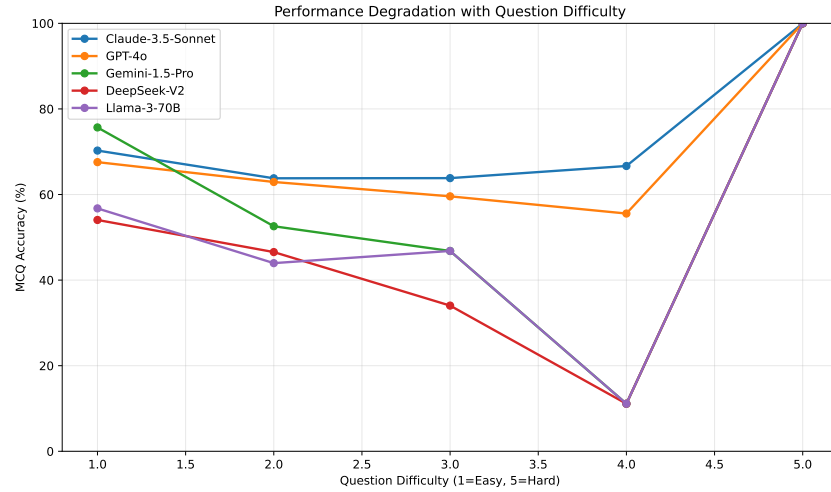


Fig. 7: MCQ-channel accuracy versus heuristic difficulty for the top five profiles. The downward trend from difficulty 1 to 4 is informative, but the single level-5 item makes the tail unusable for statistical interpretation.

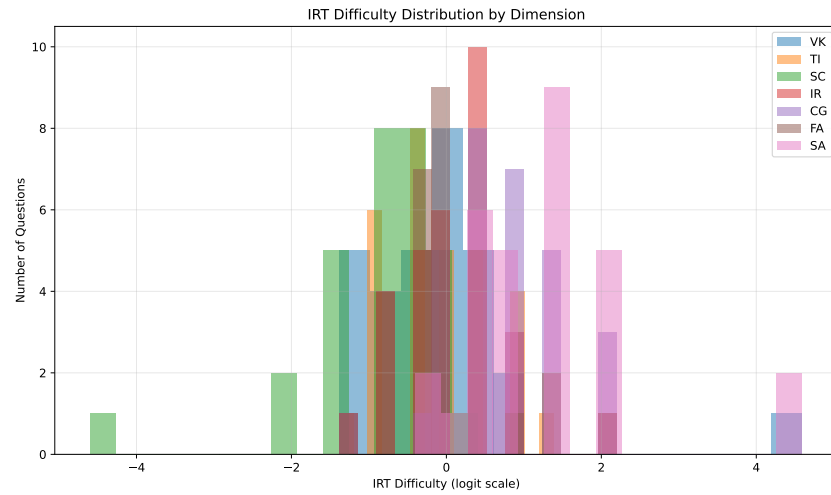


Fig. 8: IRT-style difficulty proxy distribution by dimension. The range is wide, but the bank remains dominated by easy and medium items, so the hard tail is too sparse for strong adaptive-testing claims.

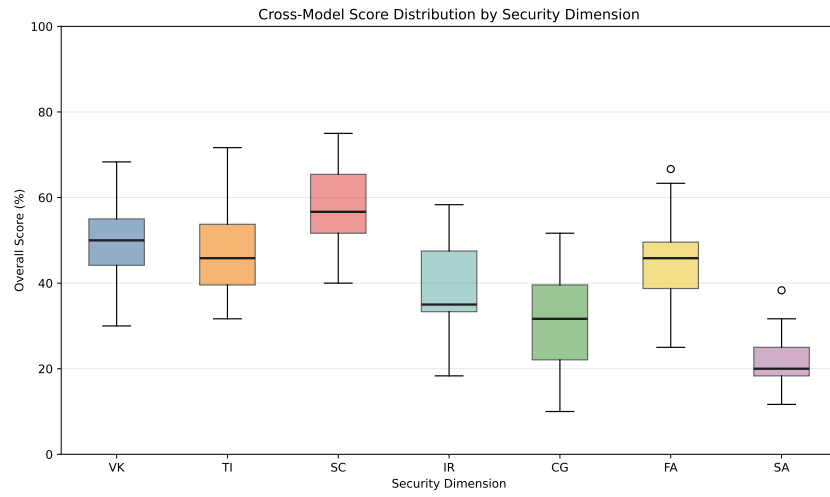


Fig. 9: Cross-model score distribution for each security dimension. Secure Coding has the highest median and the widest spread, while Governance and Security Architecture remain uniformly weak across the model set.